

QA Report — Tick & Taka (round 2)

Re-verification of the round-1 QA findings, plus a fresh audit of the code that fixed them

Project	Tick & Taka (monorepo: apps/api, apps/mobile, packages/shared)
Date	6 October 2026
Commit	<code>df29d67</code> on <code>fix/audit-2026-10-06</code> — “feat(mobile): confirm assistant money changes before they are saved”
Baseline	Round 1 at <code>3b5438b</code> (QA score 58, 26 findings); 75 commits since
Auditor role	QA Lead
Mode	Read-only. No source, config, dependency or git state changed. Scratch scripts lived in <code>_qa_tmp/</code> and were deleted.
Companion reports	UX_Report.pdf, Code_Quality_Report.pdf (written separately)

Severity scale used in all three reports: **Critical** data loss, security hole, crash or broken core flow · **High** major feature broken or a stated principle clearly violated · **Medium** real problem with a workaround, notable friction or debt · **Low** polish, consistency, minor cleanup. Round-2 findings are numbered from QA-201 so they don't collide with round-1 IDs.

1. Executive summary

70 / 100 overall QA score (round 1: 58)

The fix round worked. Of the 26 round-1 findings, 21 are fixed and 5 are partly fixed. None are unfixed or regressed. The outbox was rewritten and now behaves as promised: it keeps a write until the server accepts it, retries 5xx and unreachable servers forever, pauses on 401 instead of wiping, and lifts queued edits over the create they follow. A probe that replays real `OutboxQueue` writes against the in-memory API confirmed this. Bangla digits parse, bill payments and timer stops replay safely, and rollover and foreign-currency budgets are right. The test suite went from 185 to 568 passing tests, and the assertions are meaningful.

The new code brought new failure modes, and two are serious. **QA-201**: any signed-in user can crash the whole API in a restart loop by setting an invalid time zone. A plain `PATCH /settings` or the assistant's `update_settings` is enough, because the hourly job runner lets the error escape and Bun exits. A user database that fails migration 0004 does the same. **QA-202**: refreshing the token revokes the old one at once, so a request still carrying it gets a 401. The app then expires the session and discards the new token, which sends a daily user back to Google sign-in. Both were reproduced. Both are small fixes.

Severity	Count	Round-1 status	Count
Critical	1	Fixed	21
High	1	Partially fixed	5
Medium	5	Not fixed	0
Low	8	Regressed	0
Total new	15	Total round 1	26

Top 5 to fix first

- Critical QA-201** One user's invalid time zone, or a database that won't open, crashes the job runner. Bun exits and the API restart-loops for everyone. Reproduced.
- High QA-202** Token refresh revokes the old token at once. Any request still carrying it gets a 401, and the app throws the fresh token away and shows the login screen. Reproduced.
- Medium QA-204** One write that keeps failing with 5xx blocks every later write. While the phone is online, nothing on screen says writes are waiting. Reproduced: 55 attempts, 0 writes landed.
- Medium QA-203** An offline edit queued after "bring old tasks into today" is silently dropped by last-write-wins. Reproduced.
- Medium QA-208** The assistant still sets budgets, and edits bill, goal and event amounts, without asking for confirmation. `set_budget` also has no Undo.

2. Scope & method

What was reviewed

- **Intent:** PRODUCT.md, DESIGN.md, README.md, docs/IMPLEMENTATION_PLAN.md (including the new scope decisions) and the spec (via `_raw/spec.txt`). Requirements were carried over from round 1 and re-checked in section 4.
- **Round-1 re-verification:** each of QA-001 to QA-026 was re-checked against the current code. Where a script could reproduce it, the round-1 reproduction was run again (section 3).
- **Fresh audit, focused on new code:** the outbox (`outbox-policy.ts`, `outbox-queue.ts`, `outbox.ts`), sessions (`auth.ts`, `session.ts`, `http.ts`; API `auth/routes.ts`, `middleware/auth.ts`, `db/sessions.ts`), encryption at rest (`encrypted-storage.ts`, `secure-storage.ts`, `query-client.ts`), `/sync/changes` (API route, `sync-changes.ts`, `sync-paths.ts`), assistant money drafts and recovery (`tools.ts`, `agent.ts`, `routes.ts`, `money-drafts.ts`, `use-assistant.ts`, `recover-turn.ts`, `recovered-actions.ts`), migrations 0003–0005 and `db/client.ts`, idempotent endpoints (recurring pay, timer, checkout, restore, goals, debts, balance check), Bangla digit parsing (`digits.ts`, `calculator.ts`, `money.ts`, `quick-add.ts`), the scheduler, app lock, notifications, widget, Today date rollover and the time-entry service.

Commands and evidence

Command	Result	Source
<code>bunx biome check apps packages *.json .github</code>	484 files, exit 0	<code>_raw/lint.txt</code>
<code>bun run typecheck</code>	shared / api / mobile exit 0	<code>_raw/typecheck.txt</code>
<code>bun run test</code>	568 pass, 0 fail (shared 237, mobile 165, api 166)	<code>_raw/test.txt</code>
coverage per workspace	api 93.8% lines, shared 96.1%, mobile 92.1% (pure modules only)	<code>_raw/coverage-*.txt</code>
<code>bun audit</code>	6 advisories (2 high, 4 moderate), all transitive via Expo, Tailwind or drizzle-kit	<code>_raw/audit.txt</code>
QA probes (Bun, run from apps/api or apps/mobile): <code>shared-probe.ts</code> , <code>api-probe.ts</code> , <code>api-probe2.ts</code> , <code>refresh-race.ts</code> , <code>tz-probe.ts</code> , <code>migrate-probe.ts</code> , <code>unhandled.ts</code>	The project's own modules: <code>createTestContext</code> (in-memory SQLite, injected clock), the real mobile <code>OutboxQueue</code> and <code>http.ts</code> , and the real migrations. Upload and backup folders pointed inside <code>_qa_tmp/</code> . Output is in Appendix B.	<code>_qa_tmp/</code> (deleted afterwards)

What could not be verified (marked Unverified where it matters)

- **Anything that needs a device.** Sign-in is Google-only, and the only emulator image has no Play services, so nothing ran on a phone. This covers the app lock on a real cold start, whether the lock overlay covers an open form sheet or full-screen modal, notifications firing and quiet hours, the widget and launcher shortcuts, the biometric prompt, and Android Keystore behaviour (QA-206). It also covers AsyncStorage's 6 MB database and 2 MB-per-row limits with the encrypted cache, whether a Bangla keyboard's number pad types Bangla digits (QA-215),

cold-start ordering of token versus outbox load (QA-207), clock skew (QA-212) and the recovery of a dropped assistant stream (QA-210). These were judged by reading the code.

- **QA-202 timing.** The race was reproduced with the real `http.ts` against the in-memory API, with a 300 ms delay on the refresh reply. How often it happens on a real mobile network was not measured.
- **QA-201 under pm2.** The restart loop is inferred. It rests on two observed facts: the scheduler's rejection is unhandled (reproduced), and Bun 1.3.11 exits with code 1 on an unhandled rejection (`unhandled.ts`). Restart-on-exit is pm2's default. pm2 and Nginx were not run.
- **AI.** No real OpenAI calls were made. The API path an assistant `update_settings` call takes was reproduced. Whether a given model would emit an invalid zone name such as “Dhaka” was not.
- The screenshots in docs/screenshots predate the fixes and were not used as evidence.

3. Round-1 findings status

“Re-run” means the round-1 reproduction was run again at df29d67 and now gives the expected result. Line references are at df29d67.

ID	Sev.	Round-1 title (short)	Status	Evidence at df29d67
QA-001	C	Outbox gives up after 3 retries / on 5xx	Fixed	Own persisted queue. <code>outbox-policy.ts:L68-L77</code> retries unreachable, 5xx, 408 and 429 forever with a backoff capped at 1 min (L46-L48). Entries are saved until accepted (<code>outbox-queue.ts</code> persist and load). Tested in <code>outbox-queue.test.ts</code> . Residual visibility gap: QA-204.
QA-002	C	Offline create then edit loses the edit	Partially fixed	Re-run through the real OutboxQueue: create plus 2 edits offline, replayed 2 h later, keeps both edits (Appendix B). <code>followCreatedRecords</code> lifts queued PATCHes to the reply's stamp. The server still compares the phone's edit time with its own processing time, and bulk endpoints aren't followed: QA-203.
QA-003	H	Expired session / sign-out wipes the queue	Fixed	401 calls <code>expireSession()</code> (<code>auth.ts</code>), which keeps the profile and queue. Wipe happens only when a different user signs in (<code>mustWipeBeforeSignIn</code>). Sign-out asks first, with the pending count (<code>confirm-sign-out.ts</code>). Sliding refresh added. The refresh itself has a new race: QA-202.
QA-004	H	Offline timer records reconnect time	Fixed	Re-run: start sent 2 h late with <code>startedAt</code> gives 201; stop by id gives a 45 min entry; a replayed stop gives 200. Focus still uses the raw phone clock: QA-212.
QA-005	L	Retried actions not idempotent	Fixed	<code>crud.ts:L182-L199</code> repeat delete and restore return the row. Checkout replays by <code>transactionId</code> . Stop replays by id or window. <code>idempotency.test.ts</code> .
QA-006	L	/sync/changes unused	Fixed	<code>sync-changes.ts</code> pulls on start, reconnect and foreground, and refreshes only the screens touched (<code>sync-paths.ts</code>). Updated-at indexes in 0005.
QA-007	H	Replayed “Paid” advances due date twice	Partially fixed	Re-run: a replay with the same <code>transactionId</code> and a double tap with <code>dueAt</code> both leave next due on 2026-11-05 with one expense. Remaining: a foreign bill paid from Today is still sent without a rate (QA-213), and assistant pay drafts have no <code>dueAt</code> (QA-209).
QA-008	H	Rollover stops after first inherited month	Fixed	Re-run with budgets set once in September: carried 300k / 600k / 900k for Oct / Nov / Dec. <code>budgets.test.ts</code> .

ID	Sev.	Round-1 title (short)	Status	Evidence at df29d67
QA-009	M	USD spending counted as taka	Fixed	Re-run: a \$50 expense leaves leftToday unchanged (21400 → 21400). The client's optimistic update still subtracts it until refetch (QA-213, Low).
QA-010	L	1850/3 saves ₳616.67	Fixed	<code>expressionToMinor("1850/3") = 61700</code> (<code>calculator.ts:L140-L150</code>).
QA-011	H	Bangla digits not parsed	Fixed	Re-run: “৳ ২০” gives an expense of ₳20. “বিকাশ ৳০ bkash” gives ₳60 from bKash. “২h thesis” gives 120 min. <code>parseAmountToMinor("২৫০") = 25000</code> . Edge cases: QA-214.
QA-012	M	“weekly report” becomes repeating	Fixed	Re-run: “submit weekly report” is a one-off task that keeps its title. “read chapter 5” is a task, not ₳5. A bare edge word is a <i>low</i> -confidence guess (<code>quick-add.ts takeRecurrence</code>).
QA-013	M	Today doesn't roll over at midnight	Fixed	Query key includes the local date (<code>queries.ts:L76-L89</code>). A midnight timer and foreground both update it, and a “Showing <date>” line appears when the data is older (<code>(tabs)/index.tsx:L60-L63</code>). Unverified on device.
QA-014	L	Never-occurring rules pass validation	Fixed	Re-run: “every month on the 0th” no longer yields <code>BYMONTHDAY=0</code> , and <code>rruleSchema</code> rejects it (<code>recurrence.ts:L107-L128</code>).
QA-015	M	Undo completion leaves duplicate	Fixed	Re-run: one open copy remains, with <code>FREQ=DAILY</code> . Undo uses <code>next_id</code> (migration 0003; <code>tasks/service.ts:L271-L284</code>).
QA-016	M	Undo delete loses subtasks	Fixed	Re-run: 2 subtasks are back after Undo (<code>tasks/service.ts:L298-L316</code>).
QA-017	H	App lock skipped on cold start	Fixed	The device copy of the setting decides before settings load, and the screen is covered while it is read (<code>app-lock.tsx:L29-L34, L58-L60</code>). The first start after an update, with no device copy yet, waits for settings. Unverified on device.
QA-018	L	Login limit and bind address	Fixed	HOST defaults to 127.0.0.1 (<code>env.ts:L6</code>). The limit is 5 per 15 min. X-Real-IP is trusted only from loopback with <code>TRUST_PROXY</code> (<code>client-ip.ts</code>), as documented in the README.
QA-019	M	Assistant saves without confirmation; cap per turn	Partially fixed	Money drafts for transactions, accounts, debts, pay, contribute, repay, balance check and checkout. The cap is checked before every model call. The owner staying uncapped is a recorded scope decision. Budgets and other money fields still bypass drafts: QA-208.

ID	Sev.	Round-1 title (short)	Status	Evidence at df29d67
QA-020	M	AI calls outlive Nginx; bad output gives 500	Fixed	<code>/ai/</code> gets <code>proxy_read_timeout 120s</code> . A schema mismatch gives 502 <code>ai_error (usage.ts:L140-L153)</code> .
QA-021	L	Assistant keeps writing after stream drop	Fixed	An abort signal stops the loop (<code>routes.ts</code> , <code>agent.ts</code>). The phone recovers changes via <code>/sync/changes</code> , with a new attribution gap: QA-210.
QA-022	M	Reminder gaps; silent permission denial	Partially fixed	Tasks are picked by <code>reminderAt (reminder-window.ts)</code> . A banner shows with “Open settings”, and errors appear in Settings. Remaining (Low, not re-raised): reminders are still rescheduled only when the app opens (8-day lookahead), with no background task.
QA-023	L	No job catch-up	Fixed	A job is due when past its hour and not yet run today, plus a catch-up 10 s after start (<code>scheduler.ts</code>). That same catch-up is how QA-201 turns into a restart loop.
QA-024	L	SMS listed but missing	Fixed	IMPLEMENTATION_PLAN.md marks SMS as <i>dropped</i> , with the reason. The spec PDF itself is unchanged.
QA-025	M	Outbox, Bangla and replay edge cases untested	Fixed	outbox-policy and outbox-queue tests, Bangla quick-add table tests, timer-replay, task-undo, idempotency, budgets and migration tests. New gaps: QA-211.
QA-026	L	Coverage numbers unreliable	Partially fixed	Shared's own run now reports 100% for dates and money. The api and mobile runs still show <code>shared/src/dates.ts</code> at 6.47% and 0% lines (Bun mapping). Residual is Low, not re-raised.

Tally: 21 fixed, 5 partially fixed, 0 not fixed, 0 regressed.

4. Requirements traceability

Requirements come from the spec's build checklist and technical rules, plus PRODUCT.md, carried over from round 1. Status: **Implemented** **Partial** **Missing** **Broken**. "Implemented" means the code path exists and is tested or was read end to end. It does not mean it was run on a device.

Requirement	Implementation	Status	Notes
Sign-in, sessions, per-user SQLite + migrations	auth/routes.ts, middleware/auth.ts, db/sessions.ts, db/client.ts	Partial	Sessions are revocable and sliding. The refresh race signs users out (QA-202). Migration 0004 aborts on legacy rows (QA-201).
Auth on every protected route	app.ts, requireAuth	Implemented	Reproduced by sweeping every route without a token. Only /health, /, /privacy, /terms and /auth/google don't answer 401.
Offline cache + queued writes in order	outbox-*.ts, query-client.ts, secure-storage.ts	Partial	Core works. Gaps: a stuck head blocks the queue invisibly (QA-204), cold-start idle (QA-207), widget side queue (QA-205).
Conflicts: last write wins on updated_at	crud.ts:L170-L180, outbox-policy.ts:L95-L124	Partial	Edits after bulk moves are dropped (QA-203). Clock offset isn't persisted (QA-212).
GET /sync/changes	sync/routes.ts, sync-changes.ts	Implemented	Pulled on start, reconnect and foreground. Deletions included.
Quick-add (Bangla + English)	shared/quick-add.ts, digits.ts, calculator.ts	Implemented	Bangla digits and currency words work. Multi-amount lines and a trailing danda are mishandled (QA-214).
Tasks, subtasks, repeat on completion, undo	tasks/service.ts	Implemented	Undo is lossless (re-run).
Recurrence in plain words	shared/recurrence.ts	Implemented	Ranges and reachability are validated.
Overdue rescue, does-my-day-fit, evening, someday	tasks/service.ts:L321-L430, bulk-move.ts	Implemented	Undo names the moved tasks. Offline edit after a move is lost (QA-203).
Focus timer / time tracking	time-entries/service.ts, focus-screen.tsx	Implemented	Replays are safe. Focus uses the raw phone clock (QA-212).
Habits, streaks, freezes; routines	habits/*, routines/*	Implemented	Bangla digits ignored in the target field (QA-215).

Requirement	Implementation	Status	Notes
Accounts, computed balances, balance check	accounts/service.ts	Implemented	Balance check is idempotent by id.
Budgets: buckets, rollover; safe to spend	budgets/service.ts, shared/finance.ts	Implemented	Rollover through inherited months. Foreign currency is excluded server-side.
Bills, "Paid" creates transaction	recurring/service.ts:L95-L160	Implemented	Idempotent with transactionId and dueAt. Foreign bill on Today (QA-213), assistant draft (QA-209).
Goals, debts, calculator keypad, events, shopping	goals/, debts/, calculator.ts, events/, shopping/	Implemented	1850/3 saves ₹617.
SMS auto-capture	—	Missing	Dropped by a recorded decision.
Widget, launcher shortcuts	features/widget, use-app-shortcuts.ts	Implemented Unverified	Offline widget logs bypass the outbox (QA-205).
Local notifications, quiet hours, bill reminder	features/notifications/*	Partial	Rescheduled only on app open (QA-022 residual).
Nightly backup (keep 14), JSON export	jobs/backup.ts, scheduler.ts, sync/routes.ts	Partial	Backups are checked and caught up. One bad user stops every user's jobs and crashes the server (QA-201).
Fingerprint lock after 5 min; privacy mode	app-lock.tsx, lock-decision.ts	Implemented Unverified	Locks on cold start.
Data at rest protected	encrypted-storage.ts, secure-storage.ts	Implemented	AES-GCM with the key in the Keystore. Plain-text fallback and delete-on-decrypt-failure (QA-206). Widget data is plain (QA-205).
Login 5 / 15 min; API on 127.0.0.1	auth/routes.ts:L34, env.ts:L6	Implemented	—
AI features with graceful fallback	api/modules/ai/*	Implemented	Timeouts and schema errors give 502 ai_error.
AI never saves (money) without confirmation; cost cap	assistant/tools.ts, usage.ts	Partial	Budget and other money fields bypass drafts (QA-208).
Account deletion	DELETE /auth/account, Settings	Implemented	—

5. Findings

Grouped by category, and categories are ordered by their worst finding. **Reproduced** means a Bun script calling the project's own code produced the output shown; full output is in Appendix B.

5.1 Server & scheduled jobs

QA-201 · One user's bad data takes the whole API down: an invalid time zone or a database that won't open crashes the job runner, and the server restart-loops

Critical

Category: Server / availability / security Effort: S

Reproduced

Where: `apps/api/src/jobs/scheduler.ts:L36-L65` (loop), `:L71-L85` (startJobs).

`packages/shared/src/schemas/settings.ts:L24` (`timeZone: z.string()`).

`apps/api/src/modules/ai/assistant/tools.ts:L517-L521` (`update_settings` forwards any fields, no Undo). `apps/api/src/db/client.ts:L28-L33` plus `drizzle/0004_constraints.sql`.

What's wrong: In `runHourlyJobs` only `job.run()` is inside a try/catch. Opening the user's database (`deps.users.lease`, which also runs migrations), `readSettings` and `localParts(now, timeZone)` run inside a `try { } finally { }` with no catch, so any throw rejects the whole run. `startJobs` calls `tick()` from `croner` with no catch option, so `croner` rethrows. It also calls it from a `setTimeout 10 s` after start as `void tick()`. Nothing handles that rejection, and Bun exits with code 1. `pm2` restarts the process, the catch-up runs 10 s later, and it crashes again.

There are two reproduced triggers:

1. **Invalid time zone.** `timeZone` accepts any string, so `PATCH /settings {"timeZone":"Dhaka"}` answers 200. After that, this user's `/today` and `/budgets/safe-to-spend` answer 500, and `runHourlyJobs` rejects with `RangeError: invalid time zone`. Saying "set my time zone to Dhaka" to the assistant takes the same path. The app has no screen to change it back. The assistant can't fix it either, because it reads the time zone itself at the start of every turn.
2. **A database that won't open.** Migration 0004 rebuilds tables with new CHECKs and aborts on any old row that breaks one, even a soft-deleted row. The round-1 `transactionUpdateSchema allowed amountMinor: 0`, so such rows can exist.

```
// scheduler.ts L38-L63 (trimmed)
for (const user of deps.users.list()) {
  await yieldToRequests();
  const lease = deps.users.lease(user); // opens + migrates: may throw
  try {
    runAsUser({ user, data }, () => {
      const timeZone = readSettings(data.db).timeZone;
      const { hour } = localParts(now, timeZone); // RangeError on "Dhaka"
      for (const job of JOBS) { try { job.run(...) } catch (error) { log(...) } }
    });
  } finally { lease.release({ closeIfOpened: true }); } // no catch
}
// L80-L81
const job = new Cron("5 * * * *", { name: "per-user-jobs" }, tick); // no catch
option
const catchUp = setTimeout(() => void tick(), 10_000);
```

```
PATCH /settings {timeZone:'Dhaka'} -> 200
GET /today -> 500    GET /budgets/safe-to-spend -> 500    GET /tasks -> 200
other user GET /today -> 200
runHourlyJobs rejected: RangeError invalid time zone: Dhaka
unhandled.ts (same tick() shape, rejecting): error ... exit code 1
0004 on a DB holding one soft-deleted 0-amount expense:
  openDatabase threw ... CHECK constraint failed: transactions_amount_check
```

Why it matters: One request from any signed-in account takes the service down for every user, and backups stop running because they live in the same loop. It is a denial-of-service hole as well as a crash. The affected user is also locked out of Today with no way to recover in the app.

Recommendation:

1. Validate `timeZone` as a real IANA zone, for example `z.string().refine(tz => { try { new Intl.DateTimeFormat("en", { timeZone: tz }); return true } catch { return false } })`. Have `readSettings` fall back to the default when a stored value is invalid.
2. In the job loop, wrap each user's whole body (lease included) in try/catch, then log and continue.
3. Add `.catch(log)` to `tick()` and `catch: true` to the Cron.
4. Add a `process.on("unhandledRejection")` logger as a backstop.
5. Allow-list the keys `update_settings` may change, and give it an Undo.
6. Before rebuilding tables in 0004, repair or log rows that would fail the new CHECKs.

5.2 Sessions

QA-202 · Refreshing the session signs the user out when another request still carries the old token

High

Category: Auth / session Effort: S-M

Reproduced

Unverified on a real network

Where: `apps/api/src/modules/auth/routes.ts:L60-L65` (revoke in the same request). `apps/mobile/src/lib/http.ts:L45-L54` (401 hook). `apps/mobile/src/lib/auth.ts:L41-L56` (refresh on start), `:L80-L91` (saveSession awaits 3 SecureStore writes before setting the token), `:L150-L168` (refresh). `apps/api/test/sessions.test.ts:L47-L49` asserts the instant revoke.

What's wrong: The phone refreshes on every cold start and foreground once the token is a day old. That is exactly when the Today query, the `/sync/changes` pull and the outbox all fire with the old token. The server revokes the old session inside `/auth/refresh`, so any of those requests that arrives afterwards gets `401 session_expired`. The ky hook sees the header still matches the current token, because the new one isn't stored yet, and calls `expireSession()`, which clears the token. When the refresh reply arrives, `tokenStore.get() === token` is false and the new token is discarded. The old session is already revoked, so the user lands on the login screen. A lost refresh reply (timeout, network switch) ends the same way.

```
// refresh-race.ts: real http.ts hooks against the in-memory API, refresh reply delayed
300 ms
onUnauthorized -> expireSession(): token cleared
GET /today with the old token -> 401
refresh reply 200; tokenStore === old token? false -> DISCARDED
signed in afterwards: false
// server alone: refresh 200 | old token after refresh: 401 session_expired | new
token: 200
```

Why it matters: Nothing is lost, because the queue is kept. But a daily user is sent back to Google sign-in whenever the race hits, and sign-in needs a network and Play services. Offline-first stops working until they sign in. It undoes much of the value of the QA-003 fix.

Recommendation:

- **Server:** keep the replaced session valid for a short grace period (for example `revoked_at = now + 2 min`, or until the new jti is first used).
- **Client:** while `refreshing` is pending, make `beforeRequest` await it, and ignore a 401 for the token being refreshed. Set the new token in memory before the SecureStore writes. Add a test with a 401 arriving mid-refresh.

5.3 Offline sync & local storage

QA-203 · An edit queued after a bulk move is silently discarded on replay

Medium

Category: Offline / last-write-wins Effort: M

Reproduced

Where: `apps/api/src/lib/crud.ts:L170-L180`. `apps/api/src/modules/tasks/service.ts:L321-L372` (`rescueOverdue`), `:L383-L430` (`moveLowPriority`). `apps/mobile/src/lib/outbox-policy.ts:L95-L124`.

What's wrong: The server keeps an edit only if the phone's edit time is not older than the row's `updatedAt`, and it stamps every write with the time it is *processed*. The round-1 fix (`followCreatedRecords`) lifts queued PATCHes to that stamp, but only when the reply contains the row with `id` and `updatedAt`, at the top level or one level down. `rescue-overdue` replies { `moved: number, before: [...]` } without `updatedAt`. `move-low-priority` replies with an array, which `stampedRows` doesn't walk. So if you go offline, tap "bring old tasks into today" and then rename one of them, the rename replays with an older time than the move. The server answers 200 and leaves the row unchanged.

```
NEW bulk-then-edit: rescue-overdue then rename offline, replay 2h later -> title: "Call bank"
POST /tasks/rescue-overdue -> 200 | PATCH /tasks/01M48T... -> 200 (rename to "Call bank about card" lost)
```

Why it matters: This is silent loss of a user edit, the same class as round-1 QA-002 with a narrower trigger. The morning "bring old tasks into today" tap is a common first action.

Recommendation: Compare like with like. Store the client's last edit time separately from the server's `updatedAt`, and let a PATCH win over server-side bulk changes made before it

was tapped. Failing that, have bulk endpoints return the stamped rows and teach `stampedRows` to walk arrays. Add an outbox-plus-API replay test.

QA-204 · A write the server keeps failing blocks every later write, and nothing on screen says so while the phone is online

Medium

Category: Offline / error visibility Effort: M

Reproduced

Where: `apps/mobile/src/lib/outbox-policy.ts:L68-L77` . `apps/mobile/src/lib/outbox-queue.ts:L160-L190` . `apps/mobile/src/components/ui/sync-status.tsx:L14` (`if (online) return null`). `apps/api/src/middleware/error-handler.ts:L20-L33` (CHECK violations become 500). `apps/mobile/src/lib/sync-changes.ts:L51` .

What's wrong: The queue is strictly ordered and retries 5xx forever, which is the right default. But when one request fails deterministically with 5xx, the head entry retries every minute forever and every later write waits behind it. That happens on a server bug, or on a SQLite CHECK violation, which the error handler maps to 500 instead of 400. The `/sync/changes` pull also waits for an empty queue, so remote changes stop arriving too. The only pending indicator is hidden whenever the phone is online, so neither this case nor the round-1 scenario (Wi-Fi up, API down) is visible. There's no way to see, retry or discard a stuck write.

```
HEAD-OF-LINE (real OutboxQueue + API): PATCH /events {startsOn after endsOn} -> 500
(CHECK constraint failed: events_range_check), then a b20 expense queued behind it:
failed attempts 55 | queue size 2 | landed: [] | policy for 500: retry
```

Why it matters: The user believes their expenses are saved ("Saved on this phone. It'll sync..."). They may sit on one phone indefinitely while the server's numbers and backups drift.

Recommendation:

- Map `SQLITE_CONSTRAINT_CHECK` and `NOTNULL` to 400 `validation_error` .
- Show a pending chip whenever `outbox.size > 0` , online or not, and a "needs attention" state once the head entry has failed N times. Let the user retry or discard it there.
- Consider parking an entry after N identical 5xx failures so later writes can go.

QA-205 · Expenses logged from the widget wait in a second, plain-text queue that the app doesn't count or protect

Low

Category: Widget / offline Effort: S

Where: `apps/mobile/src/features/widget/widget-task-handler.tsx:L17-L51` . `widget-cache.ts:L35-L68` . `use-widget-sync.tsx:L41-L49` . `lib/user-data.ts:L16-L33` . `features/settings/confirm-sign-out.ts` .

What's wrong:

- Offline widget taps go to `tt.widget-pending` in plain AsyncStorage (note, amount, account), outside the encrypted outbox.

- They aren't counted in `outbox.size`, so the sign-out warning reports 0 unsynced changes, and `clearUserData` deletes them.
- The hand-over is read → enqueue → `writePendingLogs([])`, so a widget tap landing in between is lost.
- The widget cache (left-to-spend, next task title) is also plain text, unlike the “encrypted at rest” claim in `secure-storage.ts`.

Recommendation: Count pending widget logs in the sign-out check. Remove only the ids that were enqueued. Store the widget data through `secureStorage`, which the headless task can also read, or document the exception.

QA-206 · A stored value that fails to decrypt is deleted (including the offline queue), and encryption silently falls back to plain text

Low

Category: Storage / encryption Effort: S

Unverified

Where: `apps/mobile/src/lib/encrypted-storage.ts:L36-L55` . `apps/mobile/src/lib/secure-storage.ts:L11-L23` .

What's wrong: Any decrypt error removes the value. That is right for a key lost to a Keystore reset. But the same path runs if `SecureStore.getItemAsync` throws once: `storageKey()` rejects, decrypt throws, and the queued writes are deleted without a message. If the key can't be stored at all, every value is written in plain text with no log or flag.

Recommendation: Separate “wrong or missing key” (delete) from “key store unavailable” (keep, retry later). For the outbox, move undecryptable data aside and tell the user. Log the plain-text fallback.

QA-207 · On a cold start the saved queue can sit idle if it finishes loading before the session token

Low

Category: Offline / start-up Effort: S

Unverified

Where: `apps/mobile/src/app/_layout.tsx:L78-L81` . `lib/auth.ts:L41-L56` . `lib/outbox-queue.ts:L85-L101, L160-L165` . `lib/outbox.ts:L37` .

What's wrong: `load()` kicks the queue once, and `canSend()` needs a token. `loadToken()` sets the token but never kicks the outbox; `saveSession` does, but that only runs on sign-in or refresh. Suppose the token is fresh (under 24 h, so no refresh) and the network and AppState don't change. If the outbox loads first, queued writes then wait until the next foreground or network change. It is timing-dependent, and the outbox read is usually the slower one.

Recommendation: Call `outbox.kick()` at the end of `loadToken()`, or subscribe the outbox to `tokenStore`.

5.4 AI assistant

QA-208 · The assistant still changes budgets, and bill, goal and event amounts, without confirmation; `set_budget` has no Undo

Medium

Category: AI / spec deviation Effort: S

Where: apps/api/src/modules/ai/assistant/tools.ts:L53-L54 (MONEY_ENTITIES = transaction, account, debt), :L476-L515 (set_budget). prompts.ts:L55 . Spec p. 37. docs/IMPLEMENTATION_PLAN.md (“Assistant money writes are drafts”).

What's wrong: Drafting covers only three entities plus five actions. set_budget sends PUT /budgets straight away and records an action with no undo. It also writes rollover: false for the line it sets, which silently turns off a rollover the user had. Creates and edits of bill (amount), goal (target), event (budget), shopping_item (estimate) and category (budgetType , which moves a category in or out of safe-to-spend) also apply at once.

```
case "set_budget": {
  ...
  const budgets = Number(limitMinor) > 0 ? [...kept, { categoryId, limitMinor,
    rollover: false }] : kept;
  const result = await caller.call("PUT", "/budgets", { month, budgets });
  actions.push({ summary: ... });          // no undo, no draft
```

Why it matters: A misheard voice note (“b000”) can change today's safe-to-spend number with no confirmation and no Undo. That contradicts the project's own scope decision.

Recommendation: Route set_budget and the money fields of these entities through propose() . Keep the line's current rollover . Give the draft an undo that re-PUTs the previous lines.

QA-209 · Saving an older “Pay a bill” draft pays the next period as well

Medium

Category: AI / money idempotency Effort: S

Reproduced (API)

Where: apps/api/src/modules/ai/assistant/tools.ts:L408-L425 (draft body: transactionId , no dueAt). apps/api/src/modules/recurring/service.ts:L99-L112 . apps/mobile/src/features/assistant/use-assistant.ts:L219-L235 (drafts stay pending in the saved chat).

What's wrong: The Today and bill-sheet buttons send dueAt , so a repeat changes nothing. The assistant's pay draft doesn't send it. Drafts stay pending in the chat with no expiry. Suppose the bill gets paid from Today, and later the user taps Save on the old draft. That logs a second expense and moves the due date another period, which is the round-1 QA-007 outcome by another route.

```
QA-007 pay: first 200 2026-11-05 | replay 200 2026-11-05 | double-tap(dueAt) 200 2026-
11-05
                | pay without dueAt (assistant draft shape) 200 2026-12-05 | expense rows:
2
```

Recommendation: Put dueAt: bill.nextDueAt in the draft body (the tool can read the bill first). Expire or re-validate drafts on Save, for example by disabling Save when the bill's nextDueAt has moved.

QA-210 · After a dropped assistant turn, the phone's own queued writes can be listed as Tiki's changes, with an Undo that deletes them

Low

Category: AI / recovery Effort: S

Unverified

Where: `apps/mobile/src/features/assistant/use-assistant.ts:L152-L168` . `recover-turn.ts` . `recovered-actions.ts:L154-L182` (filter at L80).

What's wrong: Recovery treats every row created or changed between the turn's start and 3 min after it ended as the assistant's work. Streams drop when the connection is flaky, which is also when the outbox replays expenses logged offline. Those rows appear as "Added transaction ... · Undo", and Undo deletes a real expense.

Recommendation: Record assistant writes server-side, keyed by a turn id (for example a header the dispatcher adds), and recover from that log. Alternatively, exclude ids the outbox sent during the window.

5.5 Testing

QA-211 · The new failure paths have no tests: refresh race, job isolation, settings validation, migration on legacy rows, bulk-then-edit replay, sync pull

Medium

Category: Testing Effort: M

Where: `apps/mobile/test/` has no tests for `auth.ts` (refresh), `sync-changes.ts`, the glue in `outbox.ts` (`describe`, `applyOptimistic`), `use-assistant` or `recover-turn`, or the widget queue. `apps/api/test/sessions.test.ts:L47-L49` asserts the instant revoke that causes QA-202. No scheduler test has a user whose database or settings throw. `migrations.test.ts` seeds only rows that satisfy the new CHECKs. No test chains a bulk endpoint and a PATCH.

Quality of what exists: Good, and a big step up from 185 to 568 tests. The outbox tests drive the real queue through fakes. API tests use real routes with an injectable clock. Assertions check exact values (for example `carriedMinor: 550_000`, replay status and body equality). No flaky patterns were seen. Coverage covers pure modules well (mobile 92% of measured lines). React hooks and native glue are not measured.

Why it matters: Both the Critical and the High in this report sit in code no test reaches. The same was true in round 1.

Recommendation: Add the P0 and P1 cases in section 8.

5.6 Money, time & capture

QA-212 · Some tap times use the raw phone clock, so a phone running fast loses focus sessions and a slow one can lose offline edits

Low

Category: Time / clock skew Effort: S

Unverified

Where: `apps/mobile/src/features/focus/focus-screen.tsx:L44-L45`, `L92` (`Date.now()`). `apps/mobile/src/lib/server-clock.ts:L6-L17` (offset kept only in memory). `apps/api/src/modules/time-entries/service.ts:L19-L31` (rejects tap times more than 5 min in the future).

What's wrong: Focus start and stop use `Date.now()`, while every other write uses `editTime()`. The server-time offset is learned from responses and not persisted, so after an offline cold start `editTime()` is the raw phone clock too. Two consequences follow:

- A phone 6 min fast has its focus start rejected with 400 (dropped, with a toast), and the stop then gets 404.

- A phone a few minutes slow, edited offline after a cold start, loses last-write-wins against rows the server touched recently.

Recommendation: Use `editTime()` in focus. Persist the offset and restore it on start. On the server, clamp a slightly future tap time to `now` instead of rejecting it.

QA-213 · Foreign-currency spending still moves the taka safe-to-spend on screen, and Today's "Paid" sends foreign bills without a rate

Low Category: Money / currency Effort: S

Where: `apps/mobile/src/lib/outbox.ts:L69-L80` (`applyOptimistic`). `lib/optimistic-spend.ts:L34-L50`. `features/today/next-up.tsx:L36-L47`.

What's wrong:

- The server now leaves foreign accounts out (QA-009 fixed), but the optimistic update subtracts any expense. A \$50 card expense takes ₳50 off "left today" until the next refetch, and offline that lasts until reconnect.
- On Today, only foreign *income* opens the sheet. A USD bill whose account isn't in USD is posted straight to `/pay`, and the toast says "logged". The server then answers 400 "Enter the USD → BDT rate", and a second toast says it failed.

Recommendation: Skip the optimistic update when the account's currency isn't the default. Open the sheet for any item whose currency differs from its account's.

QA-214 · Quick-add saves only the last amount of a two-item line, and a trailing "l" turns a Bangla expense into a task

Low Category: Capture / parser Effort: S **Reproduced**

Where: `packages/shared/src/quick-add.ts:L262-L330` (amount is the last token). `calculator.ts:L124-L127` (`isAmountExpression` has no `x`).

```
"চা ২০, সিঙ্গারা ১০" {"kind":"expense","note":"চা ২০,
সিঙ্গারা","amountMinor":1000,"confidence":"high"}
"চা ২০l" {"kind":"task","title":"চা ২০l","confidence":"low"}
"lunch 2x150" {"kind":"task","title":"Lunch 2x150","confidence":"high"}
```

What's wrong:

- With two amounts, only the last is saved, at high confidence, so the AI is never asked. The preview does show ₳10, which is a partial workaround.
- A trailing danda makes the line a task when offline or with AI off.
- The keypad accepts `x` as multiply, but quick-add treats "2x150" as a high-confidence task title.

Recommendation: Mark money text with more than one amount as low confidence, or sum the amounts when they are separated by commas or "+". Strip a trailing `l`, `.` or `!` before parsing. Accept `x` and `×` in `isAmountExpression`.

QA-215 · Bangla digits in non-amount number fields are dropped without a word

Low

Category: Localisation Effort: S

Unverified

Where: `apps/mobile/src/features/habits/habit-sheet.tsx:L37` . `features/routines/routine-runner.tsx:L98` .

What's wrong: `Number("০")` is `NaN` , so the habit target silently becomes 1 and a routine step's minutes are cleared. Amount fields run through `toAsciiDigits` ; these two don't. Pasting Bangla digits triggers it. Whether the Android number pad types Bangla digits with a Bangla keyboard wasn't verified.

Recommendation: Use one helper, for example `Number(toAsciiDigits(v))` , for every typed number.

6. Strengths (keep these)

- **The outbox is now a real, testable component.** The policy is pure (`classifyFailure` , `retryDelay` , `followCreatedRecords`). The queue owns its own storage, marks a possibly delivered first entry after a restart, and keeps writes queued before load in order. A 401 pauses it rather than wiping. Writes left by the old TanStack format are migrated.
- **Idempotency by design.** Phone-made ids are used everywhere. Pay takes `transactionId` plus `dueAt` , stop takes an id, checkout takes a `transactionId` , and delete and restore return the row on repeat. Every one of these was re-run with the expected result.
- **Sessions are revocable and sliding.** A `jti` sits in a sessions table, 401 codes say why, and the server has logout and account deletion. The client keeps the profile and queue for the same person and wipes only for a different account.
- **Bangla handled at the root.** One `toAsciiDigits` runs before every parser, currency words are stripped, number words become labels (“৩ নম্বর”), and a Bangla title gets low confidence so the AI sees it. The quick-add table test covers dozens of cases.
- **The database enforces what zod enforces.** CHECK constraints, foreign keys and self-reference checks were added, and the migration is tested on a populated database.
- **Assistant safety.** The loop stops on client abort, the cost cap is checked before every model call, deletions need confirmation, model-chosen paths are checked with `isPlainPath` , and money writes in most forms are drafts.
- **Clean gates.** Lint is clean, types are clean, and 568 tests pass with exact-value assertions and an injectable clock. CI runs all three on every push.

7. Action plan

Order	ID	Title	Severity	Effort
1	QA-201	Validate time zones; isolate per-user job failures; catch tick() rejections	Critical	S
2	QA-202	Grace window for refreshed sessions; hold requests during refresh	High	S-M
3	QA-211	Tests for the paths above (P0 in section 8)	Medium	M
4	QA-204	CHECK → 400; pending/stuck indicator while online; park poison writes	Medium	M
5	QA-203	Last-write-wins that survives bulk moves	Medium	M
6	QA-208	Drafts for set_budget and other money fields; keep rollover; Undo	Medium	S
7	QA-209	dueAt in pay drafts; expire stale drafts	Medium	S
8	QA-207	Kick the outbox when the token loads	Low	S
9	QA-212	editTime() in focus; persist clock offset	Low	S
10	QA-213	Currency-aware optimistic spend and Today "Paid"	Low	S
11	QA-205	Widget queue: count, encrypt, clear by id	Low	S
12	QA-206	Don't delete the outbox on a transient key-store error	Low	S
13	QA-210	Attribute recovered changes by turn id	Low	S
14	QA-214	Multi-amount, danda and "x" in quick-add	Low	S
15	QA-215	toAsciiDigits for every typed number	Low	S

8. Recommended test plan

P0 covers the Critical and High findings, P1 the Medium ones, P2 hardening. "API" means `createTestContext`. "Integration" means the real `OutboxQueue` with `send` wired to the in-memory API, as in this audit's probes.

Pri	Type	Covers	Given / When / Then
P0	API	QA-201	Given a signed-in user, when PATCH /settings sends <code>{timeZone: "Dhaka"}</code> , then 400 and the stored zone is unchanged. Given a stored invalid zone, when GET /today runs, then 200 using the default zone.
P0	API	QA-201	Given two users where the first one's lease or settings throw, when <code>runHourlyJobs</code> runs, then it resolves, logs the failure and the second user's backup is written.
P0	Unit (api)	QA-201	Given <code>startJobs</code> with a tick that rejects, when the catch-up fires, then no unhandled rejection reaches the process (spy on <code>process.on("unhandledRejection")</code>).
P0	Migration	QA-201	Given a 0003 database holding a soft-deleted 0-amount expense, when <code>openDatabase</code> runs, then migration completes and the row is fixed or reported, not fatal.
P0	API	QA-202	Given token A refreshed into token B, when A is used within the grace window, then 200. When A is used after it, then 401 <code>session_expired</code> .
P0	Unit (mobile)	QA-202	Given a refresh in flight, when another request returns 401 for the old token, then the session isn't expired and the refreshed token is saved.
P1	Integration	QA-203	Given an overdue task, offline, when <code>rescue-overdue</code> then a rename are replayed 2 h later, then the title is the rename. The same holds for move-low-priority.
P1	API + unit	QA-204	Given a PATCH that breaks a CHECK, then 400 <code>validation_error</code> . Given a head entry failing 5xx N times, then the queue reports it as stuck and later entries go once it is parked.
P1	API (fake AI)	QA-208	Given <code>draftMoney: true</code> , when the model calls <code>set_budget</code> , then the done event has a draft and GET /budgets is unchanged.
P1	API (fake AI)	QA-209	Given a <code>pay_bill</code> draft, when the bill is paid with <code>dueAt</code> and the draft is then saved, then there is one expense and the due date moved once.
P1	Unit (mobile)	sync	Given a stored cursor and a non-empty outbox, when <code>pullChanges</code> runs, then it waits and doesn't advance the cursor. Given a reply, then the cursor equals <code>serverTime</code> and only the mapped keys refresh.
P2	Unit (mobile)	QA-207	Given the outbox loaded before the token, when <code>loadToken</code> completes, then the queue sends without any <code>AppState</code> or network event.
P2	Unit (mobile)	QA-212/213	Given a known server offset, when the app restarts offline, then <code>editTime()</code> still applies it. Given a USD account expense, then <code>applyOptimistic</code> leaves <code>leftToday</code> unchanged.
P2	Unit (shared)	QA-214	Given "চা ২০, সিঙ্গা ১০", then low confidence (or ৳30). Given "চা ২০১", then an expense of ৳20. Given "lunch 2x150", then an expense of ৳300.

Pri	Type	Covers	Given / When / Then
P2	Unit (mobile)	QA-205/206	Given pending widget logs, then the sign-out count includes them. Given a key store that throws once, when the outbox loads, then the stored queue is kept.
P2	E2E (device)	QA-202	Given a token issued 25 h ago, when the app is cold-started on mobile data, then Today loads and the login screen never appears (repeat 10 times).

9. Manual smoke test (≈15 minutes, real Android phone)

Production APK against a **staging** API. Steps marked $\triangle$ target findings in this report; a failure there confirms the finding.

#	Step	Expected
1	Cold-start while signed in.	Today loads from cache within about 2 s and the header date is today.
2 $\triangle$	Set the phone's date a day ahead (or wait a day), then cold-start on mobile data. Repeat 5 times.	No login screen (QA-202).
3	Quick-add “চা ২০”, then “রিকশা ৬০ bkash”.	Expense ৳20, then ৳60 from bKash. Safe-to-spend drops at once.
4 $\triangle$	Quick-add “চা ২০, সিঙ্গারা ১০”.	The preview should not say ৳10 with high confidence (QA-214).
5	Airplane mode: log “rickshaw 60 bkash”, open it, change it to 70. Then reconnect.	One ৳70 expense on the server.
6 $\triangle$	With an overdue task, go to airplane mode, tap “bring old tasks into today”, then rename that task. Reconnect.	The new title survives (QA-203).
7 $\triangle$	Stay on Wi-Fi, stop the API, log “tea 15” and look at Today. Start the API.	Something says 1 change is waiting, then it syncs (QA-204).
8 $\triangle$	Assistant: “set my food budget to 8000”.	A draft card to confirm, not an immediate change (QA-208).
9 $\triangle$	Assistant: “pay my internet bill”. Do <i>not</i> save. Tap “Paid” on Today, then Save the old draft.	No second expense, and the due date moves once (QA-209).
10	Start a focus session, finish it after 1 minute.	A 1 min focus entry appears in Time.
11	Turn on App lock, swipe the app away, reopen.	Fingerprint prompt before any content.
12	Open a transaction sheet, background the app for 5+ minutes, return.	The lock covers the sheet (unverified in this audit).
13 $\triangle$	Airplane mode: tap a widget quick-log. Open the app still offline and choose Sign out.	The warning counts the widget log (QA-205).
14	Settings › Numbers › Bangla.	Amounts show as ৳১,২৫০ everywhere.
15 $\triangle$	Staging only: <code>curl -X PATCH .../settings -d '{"timeZone": "Dhaka"}'</code> with a test account, then watch <code>pm2 logs</code> for 1 minute.	400. If it returns 200, expect restarts every ~10 s (QA-201).

Appendix A — Raw command output (trimmed)

Lint

```
$ bunx biome check apps packages *.json .github
Checked 484 files in 284ms. No fixes applied.
exit 0
```

Typecheck

```
@tick-taka/shared typecheck: Exited with code 0
@tick-taka/api typecheck: Exited with code 0
@tick-taka/mobile typecheck: Exited with code 0
```

Tests

```
@tick-taka/shared test: 237 pass 0 fail 486 expect() calls (12 files)
@tick-taka/mobile test: 165 pass 0 fail 453 expect() calls (31 files)
@tick-taka/api test:    166 pass 0 fail 621 expect() calls (26 files)
```

Coverage (selected lines)

```
shared All files 81.14 % funcs | 96.07 % lines
      src/quick-add.ts 95.24 | 88.75 | 396-397,525-534,548-581
mobile All files 91.93 % funcs | 92.08 % lines (pure modules only)
      src/lib/http.ts 46.15 | 80.95      src/lib/outbox-queue.ts 87.50 | 94.41
      ../../packages/shared/src/dates.ts 41.38 | 0.00  <- QA-026 residual
api     All files 86.91 % funcs | 93.78 % lines
      src/jobs/scheduler.ts 87.50 | 76.36 | 71-83  (startJobs untested)
      src/modules/ai/assistant/tools.ts 94.44 | 73.89 | ...,412-483,491-522
      (pay/goal/budget actions)
```

Dependency audit

```
braces <=3.0.3 (high), node-forge <=1.4.0 (high), postcss-selector-parser, decode-uri-
component,
esbuild (drizzle-kit, tailwindcss), uuid (moderate) – 6 vulnerabilities (2 high, 4
moderate), exit 1
```

Appendix B — QA reproduction output

Scripts imported the project's own modules: `apps/api/test/helpers.ts` (in-memory SQLite, clock fixed at Sun 4 Oct 2026 10:00 Dhaka), the real mobile `OutboxQueue` and `http.ts`, and the real drizzle migrations. Request-log lines are omitted. They lived in `docs/audit/2026-10-06-r2/_qa_tmp/` and were deleted after the run. No source file was changed.

shared-probe.ts (packages/shared)

```
"চা ২০"
{"kind":"expense","note":"চা","amountMinor":2000,"accountId":"acc_cash","confidence":"high"}
"lunch ২৫০"
{"kind":"expense","note":"lunch","amountMinor":25000,"confidence":"high"}
"বিকশা ৬০ bkaash"
{"kind":"expense","note":"বিকশা","amountMinor":6000,"accountId":"acc_bkaash","confidence":"high"}
"২h thesis"
{"kind":"time_entry","note":"thesis","minutes":120,"confidence":"high"}
"১৮৫০/০" {"kind":"expense","amountMinor":61700,"confidence":"low"}
"submit weekly report" {"kind":"task","title":"Submit weekly report","rrule":null,"confidence":"high"}
"read chapter 5" {"kind":"task","title":"Read chapter 5","rrule":null,"confidence":"low"}
"চা ২০।" {"kind":"task","title":"চা ২০।","confidence":"low"}
"চা ২০, সিঙ্গারা ১০" {"kind":"expense","note":"চা ২০, সিঙ্গারা","amountMinor":1000,"confidence":"high"}
"lunch 2x150" {"kind":"task","title":"Lunch 2x150","confidence":"high"}
parseAmountToMinor ২৫০ = 25000 ১,২৩,৪৫৬.৫০ = 12345650
expressionToMinor 1850/3 = 61700
formatAmount beng 27249000 = ৳২,৭২,৪৯০
parseRecurrence "every month on the 0th" = FREQ=MONTHLY (day 0 dropped)
isValidRRule / rruleSchema "FREQ=MONTHLY;BYMONTHDAY=0" = false / false
```

api-probe.ts / api-probe2.ts (apps/api, in-memory)

```
QA-002 raw server: PATCH 200 title: Buy milk (server LWW unchanged; fix is client-side)
QA-002 via outbox: create+2 edits offline, replay 2h later -> {"title":"Buy oat milk","notes":"2 litres"}
NEW bulk-then-edit: rescue-overdue then rename offline, replay 2h later -> title: "Call bank" (QA-203)
NEW checkout-then-edit: ["Eggs (12)"]
(no issue)
QA-007 pay: first 2026-11-05 | replay 2026-11-05 | double-tap(dueAt) 2026-11-05 | pay without dueAt 2026-12-05 | expense rows: 2
(QA-209)
QA-016 delete+restore: subtasks after undo: 2
QA-004 timer: start 201 stop 200 45 min; replayed stop 200
SESSION refresh: 200 | old token after refresh: 401 session_expired | new token: 200
(QA-202)
SYNC since: 200 {"tasks":1} deletedAt set: true
CHECK via PATCH /events {startsOn after endsOn}: 500 internal_error
(QA-204)
AUTH: routes not answering 401 without a token: GET /health, GET /, GET /privacy, GET /terms, POST /auth/google (400)
QA-008 rollover (set once in Sept): 2026-10 carried=300000, 2026-11 carried=600000, 2026-12 carried=900000
QA-009 USD $50 expense: leftToday 21400 -> 21400
QA-015 complete+undo repeating: open copies 1 rrule FREQ=DAILY
HEAD-OF-LINE: failed attempts 55 | queue size 2 | landed: [] | policy for 500: retry
(QA-204)
```

refresh-race.ts (apps/mobile http.ts + API) · tz-probe.ts · migrate-probe.ts · unhandled.ts

```
onUnauthorized -> expireSession(): token cleared
GET /today with the old token -> 401
refresh reply 200; tokenStore === old token? false -> DISCARDED
signed in afterwards: false
(QA-202)

PATCH /settings {timeZone:'Dhaka'} -> 200
GET /today -> 500 | GET /settings -> 200 | GET /budgets/safe-to-spend -> 500 | GET /tasks ->
200
other user GET /today -> 200
runHourlyJobs rejected: RangeError invalid time zone: Dhaka
(QA-201)

openDatabase threw: Failed to run the query ... | cause: SQLiteError: CHECK constraint
failed: transactions_amount_check
migrations recorded: 4 (0004/0005 not applied)
(QA-201)

error: user db failed to open ... Bun v1.3.11 (Linux x64) - exit code 1
(QA-201)
```

Appendix C — Requirement checklist used

From PRODUCT.md and the spec: log anything in under 5 s; Today answers “what now?” and “can I afford it?”; safe to spend = flexible left ÷ days left including today, fixed bills excluded; amounts in integer minor units; offline cache with queued writes sent in order, ids from the phone, last-write-wins on updated_at; Asia/Dhaka for display, local strings for habit dates and budget months; streaks with 2 freezes a month; reward, never guilt; honest numbers (balances and hours reconcile); AI rules first, cost cap, graceful fallback, minimum data, off switch, never saves (money) without confirmation; app lock after 5 min; receipts served only to authenticated requests; login limited to 5 per 15 min; Bun listens on 127.0.0.1; nightly VACUUM INTO backup keeping 14; JSON export; local notifications with quiet hours 23:00–07:00; Bangla and English quick-add.

The round-1 fix contract (../2026-10-06/_raw/FIX_CONTRACT.md) adds: revocable sliding sessions with POST /auth/refresh , logout and account deletion; a 401 never clears the queue; a wipe happens only when a different user signs in; sign-out with pending writes asks first; receipts load with a Bearer header only.

Appendix D — File inventory reviewed

Area	Files
Shared	packages/shared/src/{digits, calculator, money, quick-add, recurrence, dates}.ts, schemas/{common, money, settings, time}.ts
API core	apps/api/src/{index, app, env}.ts; middleware/{auth, error-handler}.ts; lib/{crud, client-ip, errors}.ts; db/{client, sessions, tables, user-registry (lease/data)}.ts; jobs/{scheduler, backup}.ts; drizzle/0003–0005 + meta/_journal.json
API modules	auth/{routes, session-token}, sync/routes, tasks/service, time-entries/{service, routes}, recurring/service, goals/service (contribute), debts/service, accounts/service (balance check), transactions/service, categories/routes, category-rules/{routes, service}, events/routes, settings/service
API AI	ai/usage.ts (callAi, parseAiOutput), modules/ai/{routes, prompts}.ts, assistant/{agent, tools, dispatch, fields}.ts
Mobile lib	outbox-policy, outbox-queue, outbox, http, api, auth, session, secure-storage, encrypted-storage, query-client, user-data, sync-changes, sync-paths, invalidation, server-clock, local-day, queries, optimistic-spend, today-cache, notifications, receipts, connection, event-stream, error-copy, config, polyfills
Mobile features	app/_layout.tsx, (tabs)/index.tsx; assistant/{use-assistant, money-drafts, recovered-actions, recover-turn}; security/{app-lock, app-lock-pref, lock-decision}; notifications/{use-notification-scheduler, plan-notifications, reminder-window}; settings/{reminder-status-banner, confirm-sign-out}; widget/*; quick-add/{use-quick-add, quick-add-requests}; today/{next-up, bulk-move}; time/time-tracking, focus/focus-screen, money/{event-sheet, recurring-sheet}, habits/habit-sheet, routines/routine-runner, components/ui/sync-status

Area	Files
Tests	apps/api/test/{helpers, money-helpers, idempotency, timer-replay, task-undo, budgets, sessions, migrations, handles}.test.ts; apps/mobile/test/{outbox-queue, outbox-policy, session, http-auth}.test.ts; packages/shared/test/quick-add.test.ts; file list of all three workspaces
Deploy / docs	deploy/nginx-tick-taka.conf, apps/api/ecosystem.config.cjs, apps/api/.env.example, apps/mobile/app.config.ts, README.md, docs/IMPLEMENTATION_PLAN.md, round-1 reports and _raw notes